

Caso 1: Ministerio de Educación (MINED)

Sector: Público

Metodología sugerida: COBIT 2019 (Gobierno y Gestión de TI)

1. Antecedentes Institucionales

El Ministerio de Educación (MINED) de Nicaragua es la institución rectora del sistema educativo nacional, responsable de garantizar el acceso a una educación de calidad a más de 1.8 millones de estudiantes en todo el territorio. Con una estructura que abarca 14 delegaciones departamentales y más de 6,000 centros educativos públicos, el MINED emplea aproximadamente a 85,000 docentes y personal administrativo, lo que lo convierte en uno de los empleadores más grandes del sector público. Su presupuesto anual supera los 6,000 millones de córdobas, de los cuales una parte significativa se destina a programas educativos, infraestructura escolar y, más recientemente, a la transformación digital.

En los últimos cinco años, el MINED ha impulsado un ambicioso proceso de modernización tecnológica, orientado a digitalizar los procesos administrativos y académicos. Este esfuerzo ha dado lugar a la implementación de cuatro sistemas de información críticos: el Sistema de Matrícula en Línea (SML), que permite a los padres matricular a sus hijos en escuelas públicas; el Sistema de Administración de Recursos Humanos (SARH), que gestiona nómina, plazas y expedientes del personal docente y administrativo; el Sistema de Gestión Escolar (SGE), que registra calificaciones, asistencia de estudiantes y emite certificados oficiales; y la plataforma Nicaragua Educa, un entorno virtual de aprendizaje utilizado por estudiantes de secundaria y educación a distancia.

Estos sistemas procesan información altamente sensible, incluyendo datos personales de millones de ciudadanos y menores de edad, lo que impone un alto estándar de seguridad y confiabilidad. Sin embargo, en los últimos meses han surgido múltiples señales de alerta que han puesto en duda la solidez del gobierno y la gestión de las tecnologías de información en la institución.

2. La Situación que Motiva la Auditoría

En noviembre de 2025, la Contraloría General de la República (CGR) emitió un informe preliminar derivado de una auditoría financiera practicada al MINED, en el que se advirtió sobre la existencia de debilidades significativas en los controles generales de tecnología de información. El informe señalaba que estas debilidades afectaban directamente la confiabilidad de la información financiera reportada por el ministerio, particularmente en el sistema de nómina, donde no se evidenciaba una adecuada segregación de funciones. Adicionalmente, se mencionaba que los cambios a los sistemas se realizaban sin la debida autorización y que no existía evidencia de un proceso formal de gestión de riesgos de TI. La CGR recomendó, en consecuencia, la realización de una auditoría especializada en gobierno y gestión de TI que evaluara de manera integral estos aspectos.

Paralelamente, durante el año 2025 se habían presentado una serie de incidentes que agravaron la preocupación institucional. En primer lugar, la Dirección Administrativa del MINED detectó que durante tres meses consecutivos se habían realizado pagos duplicados a 45 docentes, por un monto total aproximado de C\$ 1.2 millones. Una investigación interna preliminar sugirió que un funcionario del área de nómina había realizado modificaciones no autorizadas en el sistema SARH antes de procesar los pagos, aprovechando la falta de controles de acceso y la ausencia de pistas de auditoría que permitieran rastrear las modificaciones.

En segundo lugar, durante el período de matrícula de enero y febrero de 2025, el Sistema de Matrícula en Línea experimentó caídas recurrentes en horas de alta demanda, llegando a estar fuera de línea por períodos de hasta cuatro horas. Esto generó quejas masivas de padres de familia, así como una cobertura negativa en medios de comunicación, que cuestionaron la capacidad del ministerio para garantizar el acceso al servicio educativo.

En tercer lugar, un medio digital publicó lo que afirmaba ser una base de datos con información personal de 50,000 estudiantes, incluyendo nombres completos, direcciones y números de cédula de identidad de los padres, aparentemente extraída del SML. El MINED emitió un comunicado oficial negando la filtración, pero hasta la fecha no ha realizado una investigación técnica que permita determinar si efectivamente hubo una extracción no autorizada de datos.

Por último, la Unidad de Auditoría Interna del MINED alertó sobre el estado de obsolescencia del servidor principal que aloja los sistemas críticos. Con más de siete años de antigüedad, este equipo ya no cuenta con garantía del fabricante y no existe un plan de reemplazo definido. Además, no se ha implementado un centro de datos alternativo ni se han realizado pruebas de recuperación ante desastres en los últimos dos años, lo que expone a la institución a un riesgo de interrupción prolongada de sus servicios.

3. Gobierno de TI en el MINED: Estructura, Roles y Toma de Decisiones

Un aspecto central que explica la situación actual es la debilidad del gobierno de TI en el ministerio. El gobierno de TI, según el marco COBIT 2019, comprende las estructuras, procesos y mecanismos relacionales que aseguran que la función de TI esté alineada con los objetivos estratégicos de la organización y que sus riesgos sean gestionados adecuadamente. En el MINED, esta arquitectura de gobierno presenta importantes vacíos.

La Dirección de Tecnologías de Información (DTI) está jerárquicamente ubicada bajo el Viceministerio Administrativo, lo que refleja una visión de TI como un centro de costos y no como un socio estratégico. El director de TI no tiene acceso regular a la ministra ni participa en las reuniones del Consejo de Ministros donde se discuten los planes estratégicos. Como resultado, la planificación de TI se realiza de manera aislada y no responde a las prioridades del negocio educativo.

No existe un Comité de Tecnologías de Información o un Comité de Gobierno de TI que integre a las áreas de negocio (Dirección Académica, Dirección Administrativa, Dirección Financiera, etc.) con la DTI. Las decisiones sobre inversiones en tecnología, priorización de proyectos y aprobación de cambios estratégicos son tomadas unilateralmente por el viceministro administrativo, sin la participación de los usuarios finales, lo que ha llevado a implementaciones de sistemas que no satisfacen plenamente las necesidades operativas.

La estructura de la DTI, como se describió anteriormente, se compone de un director, tres jefaturas (infraestructura, sistemas y seguridad informática) y ocho administradores. La jefatura de seguridad informática, creada en 2024, permanece vacante desde hace ocho meses,

lo que evidencia que la seguridad no ha sido considerada una prioridad por la alta dirección. No existe un oficial de seguridad de la información (CISO) con autoridad transversal para establecer políticas y supervisar su cumplimiento.

En materia de gestión de recursos humanos, no hay un plan de carrera para el personal de TI, ni políticas de capacitación continua. La rotación es alta, especialmente entre los desarrolladores, que son atraídos por el sector privado. Esto ha generado una pérdida de conocimiento institucional y una dependencia crítica de consultores externos que, paradójicamente, tienen acceso a los sistemas de producción sin controles adecuados.

La toma de decisiones sobre inversiones en TI se realiza sin un análisis formal de costo-beneficio ni evaluación de alternativas. El presupuesto de TI para 2025 asignó C\$ 14.5 millones, de los cuales C\$ 8.5 millones fueron para operación y mantenimiento, C\$ 4.2 millones para desarrollo de sistemas, C\$ 1.2 millones para seguridad informática y C\$ 600,000 para capacitación. No se destinó ningún monto para renovación de infraestructura, a pesar de la evidente obsolescencia tecnológica. Al cierre de noviembre de 2025, la ejecución presupuestaria en seguridad apenas alcanzaba el 33% de lo asignado, mientras que en capacitación era de solo el 20%, lo que sugiere una subutilización de recursos en áreas críticas.

4. Gestión de TI: Procesos y Controles

La gestión de TI, entendida como la ejecución de las directrices establecidas por el gobierno, también presenta deficiencias significativas. El marco COBIT 2019 identifica cuatro dominios de gestión: APO (Alinear, Planificar y Organizar), BAI (Construir, Adquirir e Implementar), DSS (Entregar, Dar Servicio y Soportar) y MEA (Monitorear, Evaluar y Valorar). En cada uno de ellos se observan debilidades que han contribuido a los incidentes descritos.

En el dominio APO, no existe un Plan Estratégico de TI actualizado. El PETI 2021-2025 quedó obsoleto y no se le dio seguimiento. Tampoco se cuenta con un proceso formal de gestión de riesgos de TI, como lo señaló la CGR. No se han identificado los activos de información críticos ni se han evaluado las amenazas a las que están expuestos. En materia de gestión de inversiones,

no se utiliza ningún método para evaluar el retorno de las inversiones en TI, lo que dificulta justificar asignaciones presupuestarias ante el Ministerio de Hacienda.

En el dominio BAI, la gestión de cambios es un punto particularmente crítico. Según el testimonio de los administradores de sistemas, los desarrolladores realizan modificaciones directamente en los entornos de producción sin que medie una solicitud formal, evaluación de impacto, pruebas en ambientes separados ni aprobación del comité de cambios. Esta práctica, justificada por la necesidad de responder rápidamente a requerimientos urgentes, ha sido la causa de varios incidentes, incluyendo la desconfiguración de reportes financieros en el SARH que derivó en los pagos duplicados. Tampoco existe un proceso de aseguramiento de la calidad del software ni se realizan pruebas de aceptación por parte de los usuarios antes de pasar los cambios a producción.

En el dominio DSS, la continuidad del negocio es una asignatura pendiente. No existe un Plan de Continuidad del Negocio (BCP) ni un Plan de Recuperación ante Desastres (DRP). Los respaldos de información se realizan diariamente, pero se almacenan en el mismo servidor principal, lo que los hace vulnerables ante un fallo físico o un ataque de ransomware. Nunca se han probado restauraciones de los respaldos, por lo que no se sabe si serían efectivas en caso de una emergencia. La obsolescencia del servidor principal, combinada con la ausencia de un sitio alternativo, configura un escenario de alto riesgo de interrupción del servicio.

En materia de seguridad de la información (dominio DSS05 de COBIT), la situación es igualmente preocupante. No se ha aprobado formalmente una Política de Seguridad de la Información. La gestión de identidades y accesos es deficiente: existen cuentas de usuario de empleados activas en el SARH, no se revisan periódicamente los permisos asignados, y no se utiliza autenticación multifactor para accesos privilegiados. Los logs de acceso a los sistemas no se revisan de manera regular, lo que impide detectar a tiempo intentos de intrusión o accesos no autorizados. La filtración de datos denunciada por el medio digital, aunque no confirmada, evidencia la fragilidad de las medidas de seguridad.

Finalmente, en el dominio MEA, no se definen ni monitorean indicadores clave de rendimiento (KPI) para los procesos de TI. No existe un cuadro de mando que permita a la alta dirección Documento preparado para fines académicos. Cualquier similitud con organizaciones reales es coincidencia.

conocer el estado de la infraestructura, la seguridad o la satisfacción de los usuarios. La supervisión se limita a revisiones informales y a la atención reactiva de incidentes, sin un enfoque de mejora continua.

5. Marco Normativo y Regulatorio

El entorno normativo en el que se desenvuelve el MINED es exigente y establece obligaciones claras en materia de control interno y protección de datos. Como entidad pública, está sujeta a las Normas de Auditoría Gubernamental de Nicaragua (NAGUN), emitidas por la Contraloría General de la República, que contienen disposiciones específicas sobre la evaluación del control interno en entornos informatizados y la auditoría de sistemas de información. También debe cumplir con las Normas Técnicas de Control Interno (NTCI), que establecen requisitos mínimos de control interno para las entidades públicas.

La Ley No. 1042, Ley de Protección de Datos Personales, es otro instrumento de obligatorio cumplimiento. Esta ley impone a las instituciones públicas y privadas que tratan datos personales la obligación de implementar medidas de seguridad técnicas y organizativas para garantizar la confidencialidad, integridad y disponibilidad de los datos. También establece el deber de notificar a la autoridad de aplicación (ARESEP) y a los afectados en caso de vulneraciones de seguridad.

A nivel de políticas internas, el MINED carece de un marco normativo robusto. El borrador de Política de Seguridad de la Información de 2023 nunca fue aprobado oficialmente. No existen procedimientos documentados para gestión de cambios, gestión de accesos, gestión de incidentes, continuidad del negocio, entre otros. Esta ausencia de políticas formalizadas ha permitido que las malas prácticas se institucionalicen y que no exista una base objetiva para exigir responsabilidades.

6. Antecedentes de Auditorías Previas

En los últimos tres años, el MINED ha sido objeto de tres auditorías que abordaron parcialmente aspectos de TI. En 2023, una firma privada contratada por el propio ministerio realizó una auditoría financiera en la que señaló que "los sistemas de información no cuentan con pistas de auditoría que permitan rastrear modificaciones a datos sensibles". Este hallazgo fue presentado a la administración, pero no se implementó ninguna acción correctiva. En 2024, la Contraloría General llevó a cabo una auditoría de cumplimiento en la que identificó "la ausencia de un proceso formal de gestión de riesgos de TI". La recomendación se encuentra aún "en proceso" según el informe de seguimiento de la CGR. Ese mismo año, la Unidad de Auditoría Interna del MINED realizó una revisión que detectó "cuentas de usuario de exempleados activas en el sistema SARH", recomendando su depuración. Esta recomendación fue implementada de manera parcial, ya que si bien se eliminaron las cuentas identificadas, no se estableció un proceso recurrente para evitar que el problema se repita.

7. Actores Clave y sus Expectativas

El proceso de auditoría que se avecina involucra a varios actores con intereses y actitudes divergentes. La ministra de Educación, MSc. Carla Mendoza, se muestra públicamente preocupada por la imagen institucional que han generado los incidentes recientes. Si bien ha solicitado una auditoría rigurosa, ha dejado claro que espera que los trabajos no paralicen las operaciones diarias del ministerio. El viceministro administrativo, Lic. Roberto Martínez, parece más interesado en demostrar que los problemas han sido "exagerados" por la CGR, y se prevé que pueda mostrar cierta resistencia a aceptar hallazgos que impliquen responsabilidades para su área.

El director de TI, Ing. Francisco Talavera, es un profesional técnicamente competente, pero se encuentra abrumado por la falta de presupuesto y de personal. Reconoce abiertamente las debilidades existentes, aunque atribuye la mayoría de ellas a restricciones presupuestarias. Su jefe de sistemas, Lic. Mario Gutiérrez, defiende la labor de su equipo y tiende a minimizar los riesgos asociados a que los desarrolladores tengan acceso a producción. Por su parte, la jefa de infraestructura, Licda. Sonia Vanegas, quien ocupa el cargo de manera interina, reconoce la obsolescencia de los servidores, pero argumenta que "no hay presupuesto para renovarlos". Finalmente, el auditor interno, Lic. Ernesto Castillo, se ha mostrado colaborador y ha ofrecido

su apoyo para proporcionar información adicional que pudiera ser de utilidad para la auditoría externa.

8. El Encargo de Auditoría

Atendiendo a las recomendaciones de la Contraloría General de la República, el Viceministro Administrativo ha contratado los servicios de una firma de auditoría independiente para llevar a cabo una auditoría especializada en gobierno y gestión de TI, con especial énfasis en los sistemas críticos del ministerio: SML, SARH y SGE. La auditoría deberá seguir los lineamientos de las NAGUN y utilizar como marco de referencia principal el modelo COBIT 2019, que permita evaluar no solo los controles operativos sino también las estructuras, procesos y mecanismos de gobierno de TI.

Se espera que el equipo auditor desarrolle todas las fases del proceso metodológico de auditoría de TI, desde la planificación hasta el seguimiento, produciendo un informe que contenga hallazgos fundamentados, recomendaciones concretas y un plan de acción para su implementación. La fecha límite para la entrega del informe final es el 30 de abril de 2026.

Instrucciones para el Estudiante

Con base en la información proporcionada, desarrolle el proceso metodológico de auditoría de TI aplicando COBIT 2019 como marco de referencia principal. Para ello, deberá completar las siguientes fases:

Fase 1: Planificación

- Enfoque de auditoría: Justifique el tipo de enfoque que adoptará (basado en riesgos, de controles, sistémico o combinado), teniendo en cuenta la situación descrita.
- Objetivos de auditoría: Defina al menos tres objetivos específicos y medibles (SMART) que guíen su evaluación. Asegúrese de que reflejen los aspectos de gobierno de TI (alineamiento estratégico, estructura organizativa, gestión de riesgos, gestión de recursos, medición del desempeño, etc.) y de gestión operativa.
- Alcance de la auditoría: Establezca los límites de su revisión: qué sistemas, procesos, ubicaciones geográficas, áreas organizativas y período de tiempo serán objeto de análisis.
- Criterios de auditoría: Identifique las normas, leyes, estándares y políticas que utilizará como referencia para comparar la realidad encontrada. Debe incluir COBIT 2019 (al menos los procesos de gobierno EDM y de gestión APO, BAI, DSS, MEA), NAGUN, Ley 1042, NTCI y cualquier política interna aplicable.
- Programa de trabajo: Elabore un listado detallado de al menos diez procedimientos de auditoría (entrevistas, revisiones documentales, pruebas de cumplimiento, pruebas sustantivas, etc.) que ejecutará en la fase de trabajo de campo. Para cada procedimiento, indique el objetivo, la técnica a utilizar y el tiempo estimado.

Fase 2: Trabajo de Campo (Simulado)

Para cada uno de los siguientes dominios de COBIT 2019, simule la aplicación de al menos una técnica de auditoría y presente la evidencia obtenida (en forma de resumen de entrevista, tabla de datos analizados, captura de pantalla ficticia, etc.):

DOMINIO COBIT	ÁREA A EVALUAR	TÉCNICA SUGERIDA
EDM (EVALUAR, DIRIGIR, SUPERVISAR)	Alineamiento estratégico de TI con los objetivos educativos; existencia de estructuras de gobierno (comité de TI); papel de la alta dirección.	Entrevista con la ministra y el viceministro administrativo; revisión de actas del Consejo de Ministros y de Comités.
APO (ALINEAR, PLANIFICAR, ORGANIZAR)	Plan estratégico de TI; gestión de riesgos de TI; gestión de inversiones; estructura organizativa y perfiles.	Revisión documental del PETI; análisis de la matriz de riesgos; entrevista con el director de TI.
BAI (CONSTRUIR, ADQUIRIR, IMPLEMENTAR)	Gestión de cambios; aseguramiento de calidad; control de versiones; gestión de proveedores.	Prueba de cumplimiento sobre una muestra de cambios realizados en los últimos seis meses; entrevista con el jefe de sistemas.
DSS (ENTREGAR, DAR SERVICIO, SOPORTAR)	Continuidad del negocio y respaldos; gestión de incidentes; seguridad lógica; gestión de accesos.	Revisión de la configuración de respaldos; análisis de cuentas de usuario activas; entrevista con la jefa de infraestructura.
MEA (MONITOREAR, EVALUAR, VALORAR)	Indicadores de desempeño de TI; supervisión del cumplimiento de políticas; informes a la alta dirección.	Revisión de los reportes generados por la DTI; análisis de si existen KPI definidos y monitoreados.

Fase 3: Desarrollo de Hallazgos e Informe

Identifique al menos tres hallazgos significativos relacionados con el gobierno y la gestión de TI. Para cada hallazgo, desarrolle los cinco atributos:

- Condición: ¿Qué encontró? (describa el hecho concreto basado en las evidencias simuladas)
- Criterio: ¿Qué debería ser? (indique la referencia a COBIT 2019, NAGUN, Ley 1042, política interna, etc.)
- Causa: ¿Por qué ocurre? (identifique la causa raíz, no la excusa)
- Efecto: ¿Qué consecuencias tiene? (impacto real o potencial en el logro de los objetivos institucionales)
- Recomendación: ¿Qué hacer para corregirlo? (propuesta concreta y viable)

Redacte luego el informe de auditoría completo, con la siguiente estructura:

- Encabezado (destinatario, auditores, fecha, período auditado)
- Resumen ejecutivo (máximo una página, lenguaje no técnico)
- Objetivos y alcance
- Limitaciones (si las hubiera)
- Detalle de hallazgos (para cada uno, presentar los cinco atributos)
- Conclusiones generales
- Anexos (evidencias clave, listado de entrevistados, etc.)

Fase 4: Seguimiento

Elabore un plan de acción para implementar las recomendaciones derivadas de los hallazgos. Debe incluir:

- Actividades correctivas específicas
- Responsable(s) asignado(s) (cargos, no nombres personales)
- Plazo de implementación (fechas concretas)
- Indicador de cumplimiento (¿cómo saber que se logró?)

Además, describa la estrategia de seguimiento que realizará como auditor para verificar que las recomendaciones se implementaron de manera efectiva: plazos de revisión, evidencias a solicitar, etc.

Caso 2: Clínica “San Rafael”

Sector: Salud (Privado)

Metodología sugerida: ISO/IEC 27001:2022 (Sistema de Gestión de Seguridad de la Información)

1. Antecedentes Institucionales

La Clínica “San Rafael” es un centro de salud privado ubicado en Managua, Nicaragua, fundado hace más de 25 años. Con una trayectoria reconocida en la atención médica especializada, la clínica cuenta actualmente con 120 camas de hospitalización, 15 consultorios de especialidades, un laboratorio clínico, un área de imagenología, y una unidad de cirugía ambulatoria. Atiende un promedio de 2,500 consultas al mes y realiza aproximadamente 300 intervenciones quirúrgicas anuales. Su cuerpo médico está compuesto por 85 especialistas, y cuenta con 210 empleados administrativos y de enfermería.

En los últimos años, la clínica ha emprendido un proceso de transformación digital con el objetivo de mejorar la calidad de la atención y optimizar sus procesos administrativos. Entre las iniciativas más relevantes se encuentra la implementación de un Sistema de Historia Clínica Electrónica (HCE), que centraliza los expedientes médicos de todos los pacientes, incluyendo diagnósticos, resultados de laboratorio, imágenes, tratamientos prescritos y evolución clínica. Adicionalmente, la clínica opera un Sistema de Facturación y Aseguramiento que gestiona los cobros a pacientes particulares y a las aseguradoras con las que tiene convenio, así como un Sistema de Gestión de Recursos Humanos que maneja la nómina y los datos personales del personal.

La información manejada por la clínica es de naturaleza altamente sensible. Los historiales clínicos contienen datos de salud, considerados por la Ley No. 1042 de Protección de Datos Personales como datos especialmente protegidos. Además, la clínica procesa datos financieros de sus pacientes y del personal. La confidencialidad, integridad y disponibilidad de esta información no solo son un requisito ético y legal, sino que constituyen un elemento central de la confianza que los pacientes depositan en la institución.

2. La Situación que Motiva la Auditoría

A inicios de 2026, la clínica enfrentó una situación que puso en riesgo su reputación y generó una crisis interna. Un paciente, que había sido atendido en la unidad de maternidad, denunció ante la Dirección de la clínica que había comenzado a recibir publicidad de una empresa de productos para bebés, así como llamadas de otra clínica ofreciéndole servicios de pediatría, sin haber dado su consentimiento para que sus datos fueran compartidos con terceros. Al mismo tiempo, dos enfermeras manifestaron que habían podido acceder a los historiales clínicos de famosos que eran atendidos en la clínica, sin que existiera una razón laboral que justificara dicho acceso.

Preocupada por las implicaciones legales y reputacionales, la gerencia general solicitó una investigación interna preliminar. Dicha investigación reveló que, efectivamente, los registros de acceso al sistema HCE no reflejaban adecuadamente quién había consultado cada historia clínica, y que existían cuentas genéricas de usuario compartidas entre varios empleados. Además, se encontró que el sistema no registraba de forma automática las actividades de visualización de historiales, sino que dependía de que los usuarios hicieran un registro manual, práctica que no se cumplía.

Simultáneamente, la clínica recibió una comunicación de la Autoridad Reguladora de los Servicios Públicos (ARESEP) en su calidad de autoridad de aplicación de la Ley 1042, solicitándole un informe detallado sobre las medidas de seguridad implementadas para proteger los datos personales de los pacientes, ante la denuncia del afectado. La ARESEP advirtió que de no acreditarse medidas adecuadas, la clínica podría ser sancionada con multas que van desde los C\$ 50,000 hasta los C\$ 500,000, sin perjuicio de otras responsabilidades legales.

La gerencia general, consciente de la gravedad de la situación, decidió contratar a una firma auditora especializada para que realizara una evaluación exhaustiva de la seguridad de la información en la clínica, con el objetivo de identificar las brechas existentes, determinar el alcance de las vulnerabilidades y establecer un plan de acción que permitiera a la institución demostrar su compromiso con la protección de los datos de sus pacientes. Se ha solicitado expresamente que la auditoría se realice utilizando como marco de referencia la norma ISO/IEC

27001:2022, con miras a que, una vez implementadas las mejoras, la clínica pueda aspirar a la certificación en dicha norma.

3. Contexto de la Seguridad de la Información en la Clínica

Hasta antes de la crisis, la clínica no contaba con un Sistema de Gestión de Seguridad de la Información (SGSI) formal. La seguridad se había abordado de manera reactiva, con acciones aisladas como la instalación de antivirus en los equipos de cómputo y la contratación de un servicio de soporte técnico externo para mantener los servidores. No existía una política de seguridad de la información aprobada por la dirección, ni se habían definido roles y responsabilidades en materia de seguridad.

La gestión de accesos a los sistemas era particularmente débil. Según se pudo conocer en las primeras entrevistas, la clínica contaba con más de 300 usuarios registrados en el HCE, pero no se había realizado una depuración de cuentas en los últimos dos años. Numerosos empleados mantenían sus cuentas activas. Además, no existían perfiles diferenciados de acceso: cualquier usuario con acceso al sistema podía ver el historial completo de cualquier paciente, sin restricciones por especialidad, servicio o necesidad de conocer. Los médicos, enfermeras, administrativos e incluso personal de mantenimiento compartían la misma capacidad de visualización de datos.

En cuanto a la gestión de incidentes, no existía un procedimiento documentado para reportar y responder a violaciones de seguridad. Los empleados no habían recibido capacitación sobre sus obligaciones en materia de confidencialidad, ni sobre cómo detectar y reportar accesos sospechosos. La clínica tampoco contaba con un registro centralizado de incidentes que permitiera analizar patrones y tomar acciones preventivas.

La infraestructura tecnológica presentaba también vulnerabilidades. Los servidores que alojaban el HCE y los sistemas administrativos se encontraban en un pequeño cuarto sin control de temperatura ni acceso restringido; cualquier empleado podía ingresar sin supervisión. Los respaldos de información se realizaban diariamente, pero se almacenaban en un disco duro externo que permanecía conectado al mismo servidor, lo que los hacía vulnerables ante un

ataque de ransomware o un incendio. No se había probado nunca la restauración de los respaldos.

En materia de seguridad lógica, no se utilizaba cifrado para los datos almacenados ni para las comunicaciones internas. Las contraseñas de los usuarios eran débiles y no se exigía su cambio periódico. Tampoco existía autenticación multifactor para accesos privilegiados. Los administradores del sistema compartían una misma cuenta genérica para realizar tareas de mantenimiento, lo que impedía individualizar las acciones.

4. Marco Normativo Aplicable

La clínica está sujeta a diversas obligaciones legales y regulatorias en materia de protección de datos y seguridad de la información. En primer lugar, la Ley No. 1042, Ley de Protección de Datos Personales, establece los principios de licitud, consentimiento, calidad, seguridad y confidencialidad en el tratamiento de datos personales. En su artículo 12, impone a los responsables de bases de datos la obligación de implementar medidas de seguridad técnicas, humanas y administrativas para garantizar la confidencialidad, integridad y disponibilidad de los datos. El incumplimiento puede dar lugar a sanciones administrativas, así como a acciones civiles y penales.

Adicionalmente, el Código Penal de Nicaragua, en su artículo 204, tipifica como delito el acceso ilícito a sistemas informáticos, y en el artículo 205 sanciona la violación de la intimidad mediante la difusión de datos personales. Si bien estas disposiciones están dirigidas a los autores directos, la clínica podría enfrentar responsabilidades solidarias si no se demuestra que adoptó las medidas de seguridad exigidas.

En el ámbito sectorial, el Ministerio de Salud (MINSa) emite periódicamente normativas sobre el manejo de la historia clínica, que exigen la custodia y confidencialidad de los expedientes, tanto en formato físico como digital. La clínica está obligada a cumplir con estas disposiciones como condición para mantener su licencia de funcionamiento.

Por último, aunque la clínica no está obligada a certificarse en ISO/IEC 27001, la adopción de esta norma constituiría un referente de mejores prácticas que le permitiría demostrar ante los pacientes, las aseguradoras y las autoridades regulatorias que cuenta con un SGSI robusto.

5. Antecedentes de Incidentes Previos

En los últimos dos años, la clínica había experimentado otros incidentes menores que no fueron atendidos adecuadamente. En 2024, un empleado del área de facturación fue sorprendido accediendo a los historiales clínicos de varios pacientes con los que no tenía relación laboral. La gerencia aplicó una sanción disciplinaria, pero no investigó si otros empleados habían realizado accesos indebidos ni fortaleció los controles de acceso. En esa misma época, se perdió una laptop que contenía información de pacientes sin cifrar, pero el hecho no fue reportado a las autoridades ni a los afectados, como lo exige la Ley 1042. Estos antecedentes evidencian una cultura de seguridad débil y una falta de liderazgo en la materia.

6. Actores Clave y sus Expectativas

La gerencia general, encabezada por el Dr. Luis Alberto Mayorga, se ha mostrado muy preocupada por la denuncia ante la ARESEP. Si bien inicialmente intentó minimizar la situación, la comunicación oficial del ente regulador lo ha convencido de que es necesario tomar acciones contundentes. El Dr. Mayorga ha dejado claro que espera que la auditoría no solo identifique los problemas, sino que proponga una hoja de ruta clara para implementar un SGSI, con plazos realistas y costos razonables.

La Directora de Tecnologías de Información, Ing. Carolina Ruiz, es una profesional con experiencia en el sector público, pero lleva apenas seis meses en la clínica. Heredó un área con procesos informales y con un presupuesto reducido. A pesar de su interés en mejorar la seguridad, se ha enfrentado a la resistencia del personal médico, que considera que los controles de acceso limitan su autonomía. La Ing. Ruiz ha manifestado su apoyo a la auditoría y su deseo de que se utilice ISO 27001 como marco, pues considera que la certificación podría ayudarla a obtener los recursos que necesita.

El Jefe de Sistemas, Lic. Ricardo Pineda, es un técnico que ha estado en la clínica por más de diez años. Conoce los sistemas en profundidad, pero ha mantenido prácticas informales como el uso de cuentas compartidas y la falta de documentación. Se ha mostrado a la defensiva ante la auditoría, argumentando que "siempre se ha trabajado así" y que las restricciones de acceso dificultarían la atención médica.

El personal de enfermería y administrativo, en general, muestra poco conocimiento sobre sus responsabilidades en materia de protección de datos. La mayoría no ha recibido capacitación al respecto, y algunos confiesan haber compartido sus contraseñas con compañeros para agilizar el trabajo. Existe una percepción generalizada de que "nadie va a revisar quién entra a las historias".

7. El Encargo de Auditoría

Atendiendo a las recomendaciones de sus asesores legales y a la solicitud de la ARESEP, la gerencia general ha contratado a una firma auditora especializada en seguridad de la información para que realice una evaluación integral del SGSI de la clínica, con el objetivo de identificar las brechas con respecto a la norma ISO/IEC 27001:2022. La auditoría deberá:

- Evaluar el estado actual de los controles de seguridad de la información en la clínica, utilizando como referencia los controles del Anexo A de ISO 27001:2022.
- Identificar las debilidades en el cumplimiento de la Ley 1042 y demás normativas aplicables.
- Proponer un plan de acción para la implementación de un SGSI que permita a la clínica aspirar a la certificación en un plazo de 12 a 18 meses.
- Emitir un informe con hallazgos, recomendaciones y un plan de seguimiento.
- La auditoría deberá desarrollarse siguiendo el proceso metodológico de auditoría de TI, con las fases de planificación, trabajo de campo, desarrollo de hallazgos, comunicación de resultados y seguimiento. Se espera que el equipo auditor utilice la norma ISO 27001 como criterio principal, complementando con la Ley 1042 y las disposiciones del MINSA.

Instrucciones para el Estudiante

Con base en la información proporcionada, desarrolle el proceso metodológico de auditoría de TI aplicando ISO/IEC 27001:2022 como marco de referencia principal. Para ello, deberá completar las siguientes fases:

Fase 1: Planificación

- **Enfoque de auditoría:** Justifique el tipo de enfoque que adoptará (basado en riesgos, de controles, sistémico o combinado), teniendo en cuenta la situación descrita.
- **Objetivos de auditoría:** Defina al menos tres objetivos específicos y medibles (SMART) que guíen su evaluación. Asegúrese de que reflejen la evaluación del SGSI, la efectividad de los controles y el cumplimiento normativo.
- **Alcance de la auditoría:** Establezca los límites de su revisión: qué sistemas, procesos, ubicaciones geográficas, áreas organizativas y período de tiempo serán objeto de análisis.
- **Criterios de auditoría:** Identifique las normas, leyes, estándares y políticas que utilizará como referencia. Debe incluir ISO 27001:2022 (incluyendo los requisitos de la cláusula 4 a 10 y el Anexo A), Ley 1042 de Protección de Datos Personales, disposiciones del MINSA sobre historia clínica, y cualquier política interna aplicable.
- **Programa de trabajo:** Elabore un listado detallado de al menos diez procedimientos de auditoría (entrevistas, revisiones documentales, pruebas de cumplimiento, pruebas sustantivas, análisis técnicos, etc.) que ejecutará en la fase de trabajo de campo. Para cada procedimiento, indique el objetivo, la técnica a utilizar y el tiempo estimado.

Fase 2: Trabajo de Campo (Simulado)

Para cada una de las siguientes categorías de controles de ISO 27001:2022, simule la aplicación de al menos una técnica de auditoría y presente la evidencia obtenida (en forma de resumen de entrevista, tabla de datos analizados, captura de pantalla ficticia, etc.):

Categoría de control (anexo a)	Área a evaluar	Técnica sugerida
A.5 políticas de seguridad de la información	Existencia y aprobación de políticas de seguridad; revisión periódica; difusión al personal.	Revisión documental de las políticas; entrevista con la Directora de TI y con el Jefe de Sistemas.
A.6 organización de la seguridad de la información	Asignación de responsabilidades de seguridad; roles y funciones; contacto con autoridades; seguridad en proyectos.	Revisión de organigrama y descripciones de puestos; entrevista con gerencia general.
A.8 gestión de activos	Inventario de activos de información; clasificación de la información; manejo de soportes de almacenamiento.	Revisión del inventario de activos; observación de las instalaciones del centro de cómputo.
A.9 control de accesos	Política de control de accesos; gestión de cuentas de usuario; gestión de contraseñas; acceso privilegiado; revisión de derechos de acceso.	Análisis de cuentas de usuario activas en el HCE; prueba de cumplimiento sobre la revisión de accesos; entrevista con administradores.
A.12 seguridad de las operaciones	Gestión de cambios; protección contra malware; respaldos; gestión de incidentes; monitoreo de logs.	Revisión de la configuración de respaldos; análisis de logs de acceso; entrevista con el personal de soporte.
A.13 seguridad de las comunicaciones	Segmentación de redes; protección de comunicaciones; cifrado de datos en tránsito.	Revisión de la configuración de red y firewalls; análisis de si se utiliza cifrado en la red interna.
A.15 relaciones con proveedores	Evaluación y gestión de proveedores de servicios de TI; cláusulas de seguridad en contratos.	Revisión de contratos con proveedores de software y soporte técnico.

A.16 gestión de incidentes de seguridad

Procedimiento de respuesta a incidentes; registro y reporte de incidentes; lecciones aprendidas.

Revisión del registro de incidentes; entrevista con responsables.

Fase 3: Desarrollo de Hallazgos e Informe

- Identifique al menos tres hallazgos significativos relacionados con la seguridad de la información. Para cada hallazgo, desarrolle los cinco atributos:
- Condición: ¿Qué encontró? (describa el hecho concreto basado en las evidencias simuladas)
- Criterio: ¿Qué debería ser? (indique la referencia a ISO 27001:2022, Ley 1042, política interna, etc.)
- Causa: ¿Por qué ocurre? (identifique la causa raíz, no la excusa)
- Efecto: ¿Qué consecuencias tiene? (impacto real o potencial en la confidencialidad, integridad, disponibilidad de los datos, y en la organización)
- Recomendación: ¿Qué hacer para corregirlo? (propuesta concreta y viable)

Redacte luego el informe de auditoría completo, con la siguiente estructura:

- Encabezado (destinatario, auditores, fecha, período auditado)
- Resumen ejecutivo (máximo una página, lenguaje no técnico)
- Objetivos y alcance
- Limitaciones (si las hubiera)
- Detalle de hallazgos (para cada uno, presentar los cinco atributos)
- Conclusiones generales (incluyendo una valoración sobre la madurez del SGSI y la capacidad para certificarse en ISO 27001)
- Anexos (evidencias clave, listado de entrevistados, etc.)

Fase 4: Seguimiento

Elabore un plan de acción para implementar las recomendaciones derivadas de los hallazgos.

Debe incluir:

- Actividades correctivas específicas
- Responsable(s) asignado(s) (cargos, no nombres personales)
- Plazo de implementación (fechas concretas)
- Indicador de cumplimiento (¿cómo saber que se logró?)

Además, describa la estrategia de seguimiento que realizará como auditor para verificar que las recomendaciones se implementaron de manera efectiva: plazos de revisión, evidencias a solicitar, etc.

Caso 3: ServiTech Nicaragua S.A.

Sector: Servicios de Tecnología (BPO / Centro de Soporte)

Metodología sugerida: ITIL 4 (Gestión de Servicios de TI)

1. Antecedentes Institucionales

ServiTech Nicaragua S.A. es una empresa nicaragüense fundada en 2010, dedicada a la prestación de servicios de tecnologías de información para clientes nacionales e internacionales. Su portafolio incluye la operación de centros de atención al cliente (call centers) especializados en soporte técnico de hardware y software, la administración de infraestructura de TI para empresas de diversos sectores, y el desarrollo de soluciones de software a la medida. La empresa tiene su sede principal en Managua, con oficinas en León y Matagalpa, y emplea a más de 500 colaboradores, de los cuales aproximadamente 350 son técnicos de soporte, administradores de sistemas e ingenieros de desarrollo.

ServiTech es reconocida en el mercado local como uno de los principales proveedores de servicios gestionados (managed services). Entre sus clientes se encuentran varias empresas de zonas francas, instituciones financieras, una cadena de supermercados y, desde 2023, el propio gobierno de Nicaragua a través de un contrato para el soporte de los sistemas de atención ciudadana de tres ministerios. El modelo de negocio de ServiTech se basa en contratos de nivel de servicio (Service Level Agreements, SLA) con sus clientes, en los que se compromete a tiempos de respuesta, disponibilidad de sistemas y resolución de incidentes bajo penalizaciones económicas en caso de incumplimiento.

En los últimos dos años, la empresa ha experimentado un crecimiento acelerado, duplicando su cartera de clientes y expandiendo sus operaciones. Sin embargo, este crecimiento ha venido acompañado de problemas operativos que han comenzado a afectar su reputación y su rentabilidad. Los indicadores de satisfacción de clientes han mostrado una tendencia descendente, y en el último año la empresa ha perdido dos contratos importantes debido al incumplimiento de los niveles de servicio pactados.

2. La Situación que Motiva la Auditoría

En enero de 2026, la gerencia general de ServiTech convocó a una reunión de emergencia tras recibir una carta formal de uno de sus clientes más importantes, un banco internacional con operaciones en Nicaragua, en la que se comunicaba la intención de rescindir el contrato de soporte técnico de sus sistemas de sucursales si no se corregían de manera inmediata los siguientes problemas:

Incidentes no resueltos en plazo: El banco reportó que, durante el último trimestre de 2025, el 35% de los incidentes de alta prioridad (cajeros automáticos fuera de servicio, fallas en el core bancario) superaron el tiempo máximo de resolución pactado en el SLA (4 horas), llegando en algunos casos a más de 12 horas. Esto generó pérdidas operativas y quejas de los clientes del banco.

Falta de comunicación sobre el estado de los incidentes: El cliente señaló que no recibía actualizaciones periódicas sobre el progreso de las gestiones, y que en varias ocasiones se enteró del cierre de los incidentes por sus propios medios, sin que el centro de soporte de ServiTech le notificara formalmente.

Problemas recurrentes: El banco identificó que un mismo tipo de falla (desconfiguración de las impresoras de cheques) se repetía cada quince días en diferentes sucursales, sin que se hubiera implementado una solución definitiva.

Cambios no coordinados: El cliente denunció que en dos ocasiones se realizaron cambios en la configuración de los servidores del banco sin previo aviso, lo que afectó la disponibilidad de aplicaciones críticas durante el horario laboral.

La carta del banco incluía una advertencia clara: de no demostrar mejoras sustanciales en un plazo de 60 días, el contrato sería cancelado, lo que representaría una pérdida anual de ingresos de aproximadamente US\$ 1.2 millones para ServiTech.

La gerencia general, alarmada por la magnitud del problema, decidió contratar a una firma auditora especializada para que realizara una evaluación integral del sistema de gestión de servicios de TI de la empresa, con el objetivo de identificar las causas raíz de los incumplimientos y proponer un plan de mejora. Se solicitó expresamente que la auditoría utilizara ITIL 4 como marco de referencia, dado que es el estándar de facto para la gestión de servicios de TI y permitiría a ServiTech alinear sus procesos con las mejores prácticas internacionales.

3. Contexto de la Gestión de Servicios en ServiTech

Hasta antes de la crisis, ServiTech no había adoptado formalmente ningún marco de gestión de servicios. La operación se manejaba de manera empírica, con procesos informales heredados de la etapa inicial de la empresa. A continuación, se describen las principales áreas de gestión que presentaban debilidades, según lo que pudo recabarse en entrevistas preliminares con el personal.

3.1 Gestión de Incidentes

El centro de soporte (Service Desk) operaba con un sistema de tickets básico, pero no existían categorías de prioridad estandarizadas. Los analistas asignaban prioridades según su criterio, lo que llevaba a que incidentes de baja prioridad fueran atendidos antes que los críticos. No había un proceso claro de escalamiento: cuando un incidente no podía resolverse en el primer nivel, se asignaba a un especialista sin criterios de tiempo ni formalización. La comunicación con los clientes no estaba estandarizada; algunos analistas enviaban correos, otros llamaban por teléfono, y no se registraban las interacciones en el sistema de tickets.

3.2 Gestión de Problemas

No existía una práctica formal de gestión de problemas. Los incidentes recurrentes, como el de las impresoras de cheques, se resolvían de manera reactiva sin investigar la causa raíz. El equipo de soporte no contaba con una base de datos de errores conocidos (Known Error Database, KEDB) que permitiera documentar soluciones temporales y permanentes. Como resultado, los mismos problemas se repetían indefinidamente, generando insatisfacción en los clientes y desperdiciando recursos.

3.3 Gestión de Cambios

La gestión de cambios era casi inexistente. Cualquier administrador de sistemas podía realizar modificaciones en los entornos de los clientes sin autorización previa, sin evaluación de impacto y sin plan de reversión. Las dos ocasiones en que se afectó la disponibilidad del banco ocurrieron precisamente por cambios no autorizados. No existía un Comité de Cambios (CAB) que evaluara las solicitudes, ni se documentaban los cambios realizados.

3.4 Gestión de Niveles de Servicio

Si bien los contratos con los clientes contenían SLA, no se realizaba un seguimiento formal de su cumplimiento. Los reportes de desempeño eran esporádicos y, cuando se generaban, no se compartían con los clientes de manera proactiva. No se definían objetivos de nivel de servicio (SLR) internos para cada equipo, ni se vinculaban los SLA con los procesos de mejora continua. Los analistas de soporte desconocían los tiempos de respuesta y resolución a los que se habían comprometido.

3.5 Gestión de Capacidad y Disponibilidad

Aunque ServiTech administraba infraestructura crítica para sus clientes, no contaba con procesos formales de gestión de capacidad y disponibilidad. No se monitoreaban proactivamente los umbrales de uso de recursos, y los aumentos de capacidad se realizaban solo cuando se presentaban fallas. Esto había llevado a que en varias ocasiones los servidores colapsaran por picos de demanda no previstos, afectando la disponibilidad de los sistemas.

3.6 Gestión de Configuración

No existía una base de datos de gestión de configuración (CMDB) que registrara los activos de TI de los clientes y sus relaciones. Cada administrador manejaba sus propios inventarios, a menudo desactualizados. Esto dificultaba la identificación de los componentes afectados por incidentes y aumentaba el tiempo de resolución.

4. Cultura Organizacional y Capacidades del Personal

La cultura de ServiTech se caracterizaba por un fuerte énfasis en la operación diaria y una escasa planificación estratégica. Los técnicos de soporte eran valorados por su capacidad "apaga fuegos", y las horas extras eran la norma. La gerencia media carecía de formación en gestión de servicios; la mayoría de los jefes de equipo habían sido promovidos desde puestos técnicos sin recibir capacitación en liderazgo o gestión de procesos.

La rotación de personal en el área de soporte era elevada (alrededor del 30% anual), lo que dificultaba la consolidación del conocimiento y la estandarización de prácticas. Los nuevos analistas recibían una capacitación breve de una semana, enfocada en los sistemas técnicos, pero sin instrucción sobre los procesos de servicio ni sobre la importancia de los SLA.

No existía una función de "dueño del proceso" (process owner) para ninguna de las áreas de gestión. Las responsabilidades estaban difusas y cada jefe actuaba según su propio criterio. La gerencia general había delegado la operación en el gerente de operaciones, quien se mostraba reacio a establecer procesos formales por considerar que "burocratizarían" el trabajo y restarían agilidad.

5. Marco Normativo y Estándares de Referencia

Aunque ServiTech no está sujeta a regulaciones sectoriales específicas como las financieras, sus contratos con clientes de la banca y el gobierno imponen exigencias implícitas en materia de disponibilidad, seguridad y continuidad. En particular, los contratos con instituciones financieras remiten a las normativas de la SIBOIF en cuanto a la continuidad operativa, lo que indirectamente obliga a ServiTech a mantener estándares elevados.

La adopción de ITIL 4 se presenta como una oportunidad para estandarizar los procesos de gestión de servicios, alinear la operación con las expectativas de los clientes y demostrar capacidad de mejora continua. La empresa ha considerado también la posibilidad de obtener una certificación en la norma ISO/IEC 20000-1 (Gestión de Servicios de TI) en el mediano plazo, pero para ello necesita primero implementar los procesos básicos de ITIL.

6. Antecedentes de Problemas Similares

En los últimos dos años, la empresa había recibido quejas recurrentes de otros clientes sobre la falta de comunicación y los tiempos de respuesta. En 2024, un cliente del sector de zonas francas rescindió un contrato por causas similares a las planteadas por el banco. La gerencia general atribuyó esa pérdida a "incompatibilidad cultural", sin realizar un análisis profundo de las causas. En la auditoría interna de 2024 se había señalado la necesidad de implementar procesos formales de gestión de incidentes y cambios, pero las recomendaciones no fueron implementadas por considerarse de baja prioridad.

7. Actores Clave y sus Expectativas

La gerencia general está encabezada por el Sr. Carlos Fonseca, fundador de la empresa, quien ha construido el negocio con base en relaciones personales y un enfoque comercial agresivo. Ante la amenaza de perder al cliente bancario, ha asumido un rol más activo y ha solicitado la auditoría, aunque mantiene reservas sobre la adopción de metodologías formales, que asocia con "procedimientos lentos".

El gerente de operaciones, Ing. Miguel Ángel Reyes, es un ingeniero con amplia experiencia técnica, pero con poca formación en gestión. Ha sido el principal opositor a los cambios de procesos, argumentando que "lo que funciona es la acción rápida". Su estilo de liderazgo es reactivo y centralizador; toma decisiones sin consultar a sus equipos.

La jefa de soporte, Licda. Ana Lucía Castro, es una profesional con experiencia en centros de servicio de empresas multinacionales. Fue contratada hace un año con la misión de profesionalizar el área, pero se ha enfrentado a la resistencia del gerente de operaciones y a la falta de presupuesto para herramientas. Ve la auditoría como una oportunidad para generar evidencia de las necesidades de mejora.

El personal técnico, en su mayoría joven, muestra disposición a aprender, pero está agotado por las jornadas extenuantes y la falta de reconocimiento. Muchos confiesan que no entienden por qué se pierden clientes si "siempre resuelven los problemas".

8. El Encargo de Auditoría

La gerencia general ha contratado a una firma auditora especializada en gestión de servicios de TI para que realice una evaluación integral de los procesos de servicio de ServiTech, utilizando ITIL 4 como marco de referencia. La auditoría deberá:

- Evaluar el estado actual de los procesos de gestión de incidentes, problemas, cambios, niveles de servicio, configuración, capacidad y disponibilidad, identificando las brechas con respecto a las prácticas de ITIL 4.
- Analizar las causas raíz de los incumplimientos de SLA con el cliente bancario y de los problemas recurrentes.
- Proponer un plan de implementación priorizado para adoptar los procesos clave de ITIL, incluyendo la definición de roles, la selección de herramientas y la capacitación del personal.
- Emitir un informe con hallazgos, recomendaciones y un plan de seguimiento con hitos claros.
- Se espera que el equipo auditor desarrolle todas las fases del proceso metodológico de auditoría de TI, con especial énfasis en la observación de la operación diaria, la revisión de los registros de tickets y la realización de entrevistas a todos los niveles.

Instrucciones para el Estudiante

Con base en la información proporcionada, desarrolle el proceso metodológico de auditoría de TI aplicando ITIL 4 como marco de referencia principal. Para ello, deberá completar las siguientes fases:

Fase 1: Planificación

- **Enfoque de auditoría:** Justifique el tipo de enfoque que adoptará (basado en riesgos, de controles, sistémico o combinado), teniendo en cuenta la situación descrita y la urgencia de corregir los incumplimientos con el cliente bancario.
- **Objetivos de auditoría:** Defina al menos tres objetivos específicos y medibles (SMART) que guíen su evaluación. Asegúrese de que reflejen la evaluación de los procesos de gestión de servicios (incidentes, problemas, cambios, niveles de servicio, etc.) y su alineación con las prácticas de ITIL 4.
- **Alcance de la auditoría:** Establezca los límites de su revisión: qué procesos, sistemas, ubicaciones geográficas, áreas organizativas y período de tiempo serán objeto de análisis. Considere si incluirá a los clientes (especialmente el banco) como parte de la revisión.
- **Criterios de auditoría:** Identifique las normas, estándares y políticas que utilizará como referencia. Debe incluir ITIL 4 (prácticas de gestión de incidentes, problemas, cambios, niveles de servicio, configuración, capacidad, disponibilidad, etc.), los SLA firmados con los clientes, y cualquier política interna existente.
- **Programa de trabajo:** Elabore un listado detallado de al menos diez procedimientos de auditoría (entrevistas, revisiones documentales, pruebas de cumplimiento, análisis de datos de tickets, observación de reuniones, etc.) que ejecutará en la fase de trabajo de campo. Para cada procedimiento, indique el objetivo, la técnica a utilizar y el tiempo estimado.

Fase 2: Trabajo de Campo (Simulado)

Para cada una de las siguientes prácticas de ITIL 4, simule la aplicación de al menos una técnica de auditoría y presente la evidencia obtenida (en forma de resumen de entrevista, tabla de datos analizados, captura de pantalla ficticia, etc.):

Práctica de ITIL 4	Área a evaluar	Técnica sugerida
Gestión de incidentes	Registro, clasificación, priorización, escalamiento, comunicación, resolución y cierre de incidentes; cumplimiento de SLA.	Análisis de una muestra de tickets de incidentes del último trimestre; entrevista con analistas de soporte.
Gestión de problemas	Identificación de problemas recurrentes; análisis de causa raíz; registro en KEDB; implementación de soluciones permanentes.	Revisión de incidentes recurrentes (ej. impresoras de cheques); entrevista con el responsable de problemas (si existe).
Gestión de cambios	Solicitud, evaluación de impacto, autorización, planificación, implementación, verificación y cierre de cambios.	Prueba de cumplimiento sobre una muestra de cambios realizados en los últimos seis meses; revisión de actas del CAB.
Gestión de niveles de servicio	Definición de SLA; monitoreo y reporte de cumplimiento; revisión periódica con clientes; gestión de mejora.	Revisión de los acuerdos de nivel de servicio firmados; análisis de los reportes de desempeño generados.
Gestión de configuración	Inventario de activos; relaciones entre componentes; actualización de la CMDB.	Revisión del inventario de activos de los clientes; comparación con lo registrado en el sistema de tickets.
Gestión de capacidad y disponibilidad	Monitoreo de uso de recursos; planificación de capacidad; disponibilidad de servicios críticos.	Revisión de los registros de monitoreo de servidores; entrevista con administradores de sistemas.

Fase 3: Desarrollo de Hallazgos e Informe

Identifique al menos tres hallazgos significativos relacionados con la gestión de servicios de TI. Para cada hallazgo, desarrolle los cinco atributos:

- Condición: ¿Qué encontró? (describa el hecho concreto basado en las evidencias simuladas)
- Criterio: ¿Qué debería ser? (indique la referencia a las prácticas de ITIL 4, los SLA, políticas internas, etc.)
- Causa: ¿Por qué ocurre? (identifique la causa raíz, no la excusa)
- Efecto: ¿Qué consecuencias tiene? (impacto en la satisfacción del cliente, en el cumplimiento de SLA, en la eficiencia operativa)
- Recomendación: ¿Qué hacer para corregirlo? (propuesta concreta y viable, incluyendo acciones a corto, mediano y largo plazo)

Redacte luego el informe de auditoría completo, con la siguiente estructura:

- Encabezado (destinatario, auditores, fecha, período auditado)
- Resumen ejecutivo (máximo una página, lenguaje no técnico, con énfasis en los riesgos para la continuidad del negocio)
- Objetivos y alcance
- Limitaciones (si las hubiera)
- Detalle de hallazgos (para cada uno, presentar los cinco atributos)
- Conclusiones generales (incluyendo una valoración de la madurez de los procesos de servicio y las acciones prioritarias)
- Anexos (evidencias clave, listado de entrevistados, etc.)

Fase 4: Seguimiento

Elabore un plan de acción para implementar las recomendaciones derivadas de los hallazgos.

Debe incluir:

- Actividades correctivas específicas, diferenciando acciones inmediatas (para recuperar la confianza del banco) y acciones estructurales (para implementar ITIL).
- Responsable(s) asignado(s) (cargos, no nombres personales)
- Plazo de implementación (fechas concretas)
- Indicador de cumplimiento (¿cómo saber que se logró?)

Además, describa la estrategia de seguimiento que realizará como auditor para verificar que las recomendaciones se implementaron de manera efectiva: plazos de revisión, evidencias a solicitar, y cómo evaluará la efectividad de los nuevos procesos.

Caso 4: Cooperativa de Ahorro y Crédito “La Unión” R.L.

Sector: Financiero (Cooperativa de ahorro y crédito)

**Metodología sugerida: COSO (Control Interno) y Metodologías de Gestión de Riesgos
(COSO ERM / NIST SP 800-30 / MAGERIT)**

1. Antecedentes Institucionales

La Cooperativa de Ahorro y Crédito “La Unión” R.L. es una entidad financiera de carácter solidario con más de 25 años de operación en Nicaragua. Su domicilio principal se ubica en la ciudad de Matagalpa, y cuenta con sucursales en Jinotega, Estelí y Managua. Atiende a más de 35,000 socios, entre pequeños productores, comerciantes, empleados públicos y jubilados. Su cartera de crédito supera los 1.200 millones de córdobas y los depósitos de sus socios ascienden a aproximadamente 900 millones de córdobas.

La cooperativa está supervisada por la Superintendencia de Bancos y de Otras Instituciones Financieras (SIBOIF) , que la clasifica como una entidad de segundo nivel por su tamaño y volumen de operaciones. En los últimos años, “La Unión” ha experimentado un crecimiento sostenido, impulsado por la expansión de los servicios financieros digitales: ofrece banca en línea, transferencias electrónicas, banca móvil y una aplicación para pagos con código QR.

Sin embargo, el crecimiento no ha ido acompañado de un fortalecimiento equivalente en su sistema de control interno ni en su gestión de riesgos tecnológicos. La entidad ha operado tradicionalmente con un enfoque artesanal, confiando en la experiencia de sus directivos y en la fidelidad de su personal, sin contar con políticas formales ni estructuras de gobierno de riesgo.

2. La Situación que Motiva la Auditoría

En diciembre de 2025, la SIBOIF realizó una inspección in situ que incluyó una evaluación de los riesgos de tecnologías de información. Los resultados de esa inspección fueron remitidos al Consejo de Administración de la cooperativa mediante un oficio reservado, en el que se identificaban deficiencias críticas que, de no ser corregidas en un plazo de 90 días, podrían derivar en medidas administrativas que van desde multas hasta la intervención de la entidad.

Documento preparado para fines académicos. Cualquier similitud con organizaciones reales es coincidencia.

El informe de la SIBOIF destacaba los siguientes hallazgos:

- Ausencia de un proceso formal de gestión de riesgos de TI: La cooperativa no contaba con un marco de identificación, análisis y evaluación de los riesgos tecnológicos. No se habían identificado activos críticos, ni se habían evaluado las amenazas a los sistemas de información.
- Falta de segregación de funciones: El administrador del sistema core bancario tenía acceso a la creación de usuarios, asignación de perfiles, procesamiento de transacciones y generación de reportes contables, concentrando funciones que deberían estar separadas.
- Inexistencia de un plan de continuidad del negocio: No se había elaborado un análisis de impacto al negocio (BIA), no existía un sitio alternativo de procesamiento y los respaldos se almacenaban en la misma sala de servidores, sin que se hubieran realizado pruebas de restauración.
- Debilidades en los controles de acceso: Se detectaron cuentas de usuario de empleados activas, ausencia de autenticación multifactor para accesos remotos, y una contraseña genérica compartida entre varios empleados de la sucursal de Estelí.
- Falta de un programa de auditoría interna de TI: La Unidad de Auditoría Interna no incluía en su plan anual revisiones específicas sobre los sistemas de información, pese a los riesgos inherentes al sector financiero.

El Consejo de Administración, presidido por un grupo de socios con experiencia comercial pero escaso conocimiento técnico, se mostró sorprendido por la gravedad de las observaciones. Ante la inminente amenaza de una sanción regulatoria, decidió contratar a una firma auditora especializada para que realizara una auditoría integral del control interno y la gestión de riesgos de TI, con el objetivo de identificar las brechas existentes y desarrollar un plan de acción que permitiera cumplir con las exigencias de la SIBOIF en el plazo establecido.

La auditoría deberá utilizar como marco de referencia el modelo COSO (para la evaluación del control interno) y las metodologías de gestión de riesgos como COSO ERM, NIST SP 800-30 o MAGERIT, con el fin de establecer un sistema de administración de riesgos tecnológicos acorde con las mejores prácticas y las expectativas del regulador.

3. Contexto del Control Interno y la Gestión de Riesgos

3.1 Estructura organizativa y ambiente de control

La cooperativa está gobernada por un Consejo de Administración de siete miembros, elegidos por la asamblea general de socios. El Consejo delega la gestión ejecutiva en un Gerente General, quien a su vez coordina las áreas de Negocios, Operaciones, Finanzas y Tecnología. No existe un Comité de Riesgos ni un oficial de cumplimiento normativo (Compliance) con dedicación exclusiva. El Consejo se reúne una vez al mes y, según consta en las actas, los temas de tecnología de información nunca han sido tratados en profundidad; las decisiones relacionadas con TI se han tomado exclusivamente por la Gerencia General.

La cultura organizacional se caracteriza por un fuerte arraigo a las relaciones personales y la confianza mutua. Muchos de los funcionarios clave llevan más de 15 años en la cooperativa, y se han establecido prácticas informales que han reemplazado a los procedimientos escritos. Por ejemplo, las autorizaciones de créditos superiores a los límites establecidos se gestionan mediante llamadas telefónicas o mensajes de WhatsApp, sin quedar registradas formalmente.

El área de Tecnología de Información está compuesta por un jefe de sistemas, dos administradores de bases de datos y tres técnicos de soporte. No existe un área separada de seguridad de la información. El jefe de sistemas reporta directamente al Gerente General, pero carece de presupuesto propio y de autoridad para establecer políticas que impacten a otras áreas.

3.2 Evaluación de riesgos

La cooperativa nunca ha realizado un ejercicio formal de identificación y análisis de riesgos tecnológicos. No se cuenta con un inventario de activos de información clasificados por criticidad, ni con una matriz de riesgos que identifique amenazas, vulnerabilidades y controles. Los directivos confían en que “nunca ha pasado nada grave” y que los sistemas están suficientemente protegidos porque cuentan con antivirus y un firewall proporcionado por el proveedor de internet.

3.3 Actividades de control

Los controles existentes son básicos y, en muchos casos, ineficaces:

- Controles generales de TI: No hay políticas de seguridad aprobadas; la gestión de usuarios es manual y no se realizan revisiones periódicas; los cambios a los sistemas no requieren autorización formal; no existe un plan de continuidad del negocio; la seguridad física del centro de datos es deficiente (la sala de servidores no tiene puerta con cerradura especial, ni control de temperatura, ni sistema de extinción de incendios).
- Controles de aplicación: El sistema core bancario, desarrollado por un proveedor externo, permite la creación de usuarios sin necesidad de aprobación superior. No hay validaciones automáticas para evitar que un mismo empleado realice transacciones incompatibles (por ejemplo, registrar un crédito y aprobarlo). Los logs de auditoría se generan pero nunca se revisan.

3.4 Información y comunicación

La cooperativa no cuenta con canales formales para que los empleados reporten irregularidades o debilidades de control. Los manuales de políticas y procedimientos están desactualizados o no existen. No se realizan capacitaciones periódicas sobre control interno, riesgos o protección de datos. Los reportes a la SIBOIF se elaboran con base en información extraída del sistema, pero no se verifica la integridad y exactitud de los datos antes de su envío.

3.5 Supervisión y monitoreo

La Gerencia General no realiza un seguimiento sistemático del desempeño de los controles. La Unidad de Auditoría Interna, compuesta por un auditor principal y un auxiliar, ejecuta un plan anual enfocado casi exclusivamente en créditos y operaciones financieras, sin incluir revisiones de TI. La auditoría interna no ha recibido capacitación en auditoría de sistemas y carece de herramientas técnicas para evaluar los controles informáticos.

4. Riesgos Tecnológicos Identificados Preliminarmente

A partir de las observaciones de la SIBOIF y de una revisión preliminar realizada por los asesores legales, se han identificado los siguientes riesgos significativos:

Riesgo	Descripción	Impacto potencial
Riesgo de fraude interno	Concentración de funciones en el administrador del core bancario permite que una sola persona pueda crear usuarios, asignar permisos y realizar transacciones no autorizadas.	Pérdidas financieras por apropiación indebida; sanciones regulatorias; pérdida de confianza de los socios.
Riesgo de indisponibilidad de sistemas	Ausencia de un plan de continuidad del negocio y de un sitio alternativo; respaldos no probados; obsolescencia del servidor principal.	Interrupción prolongada de los servicios financieros; violación de las normas de la SIBOIF; pérdida de depósitos.
Riesgo de ciberataque	Controles de acceso débiles, ausencia de autenticación multifactor, falta de segmentación de red, políticas de contraseñas débiles.	Acceso no autorizado a información de socios; robo de fondos a través de transferencias no autorizadas; daño reputacional.
Riesgo de incumplimiento normativo	Falta de políticas formales, ausencia de gestión de riesgos, deficiencias en la auditoría interna.	Sanciones económicas; inhabilitación de la cooperativa para recibir depósitos; intervención por parte de la SIBOIF.
Riesgo de fuga de información	Almacenamiento sin cifrar de datos sensibles; cuentas de empleados activas; ausencia de controles de acceso a la información.	Multas por incumplimiento de la Ley 1042; denuncias de socios; exposición mediática.

5. Marco Normativo Aplicable

La cooperativa está sujeta a un riguroso marco regulatorio financiero y de protección de datos:

- Normas de la SIBOIF sobre Gestión de Riesgos de Tecnologías de Información: Exigen a las entidades financieras contar con políticas, procedimientos y un sistema de gestión de riesgos de TI que incluya la identificación, análisis, monitoreo y control de riesgos, así como planes de continuidad del negocio.
- Norma sobre Gestión de Seguridad de la Información (SIBOIF): Establece los controles mínimos en materia de seguridad lógica, gestión de accesos, protección de datos y respuesta a incidentes.
- Ley No. 1042, Ley de Protección de Datos Personales: Obliga a las entidades financieras a proteger los datos personales de sus clientes, implementando medidas de seguridad técnicas y organizativas.
- Código de Comercio y Ley General de Bancos, Instituciones Financieras y otras entidades financieras: Imponen deberes de diligencia y transparencia en la gestión de los recursos de los depositantes.
- Adicionalmente, el marco COSO y las metodologías de gestión de riesgos (COSO ERM, NIST SP 800-30, MAGERIT) constituyen las mejores prácticas que la cooperativa puede adoptar para estructurar su sistema de control interno y su gestión de riesgos.

6. Antecedentes de Incidentes Previos

Aunque no se había producido un fraude de grandes proporciones, la cooperativa había experimentado incidentes menores que debieron haber alertado sobre la fragilidad de los controles:

- En 2024, una falla en el servidor principal dejó la sucursal de Jinotega sin conexión al sistema durante dos días. Los empleados tuvieron que registrar las operaciones en cuadernos físicos y transcribirlas posteriormente, generando errores y demoras.
- Un expleado, despedido en 2023, mantuvo acceso al sistema core durante casi un año después de su salida. El acceso fue detectado casualmente cuando otro empleado intentó usar su cuenta y notó que seguía activa.
- En 2025, un cliente denunció que le habían descontado de su cuenta un préstamo que no había solicitado. La investigación interna reveló que un funcionario de la sucursal de Estelí había utilizado la cuenta genérica compartida para aprobar el crédito sin autorización.

Ninguno de estos incidentes fue reportado a la SIBOIF, y las acciones correctivas se limitaron a soluciones puntuales, sin abordar las causas raíz.

7. Actores Clave y sus Expectativas

El Consejo de Administración, presidido por el Sr. José Luis Canales, un productor de café con amplia trayectoria comercial, se enfrenta ahora a la presión regulatoria. Los consejeros tienen un conocimiento limitado de TI, pero están muy preocupados por la reputación de la cooperativa y por las posibles sanciones. Esperan que la auditoría les entregue un diagnóstico claro y una hoja de ruta que puedan presentar a la SIBOIF como evidencia de su compromiso correctivo.

El Gerente General, Lic. Héctor Zamora, ha sido el principal responsable de la gestión de la cooperativa durante los últimos doce años. Goza de la confianza del Consejo, pero ha mostrado resistencia a invertir en controles y en tecnología, argumentando que “los socios no pagan por eso”. Ante la inminente intervención regulatoria, ha cambiado de postura y ahora se muestra

colaborador, aunque algunos consejeros dudan de su capacidad para liderar las transformaciones necesarias.

El Jefe de Sistemas, Ing. René Blandón, es un técnico autodidacta con gran conocimiento del core bancario, pero con escasa formación en gestión de riesgos o control interno. Ha defendido el statu quo, argumentando que “los problemas son de procedimiento, no de sistemas”. Su resistencia a implementar controles más estrictos (como la autenticación multifactor) se basa en la creencia de que complicarían la operación.

La Unidad de Auditoría Interna, liderada por la Licda. Silvia Espinoza, ha solicitado reiteradamente recursos para capacitarse en auditoría de TI y para incluir revisiones informáticas en su plan anual. Hasta ahora sus peticiones habían sido ignoradas. Ve la auditoría externa como una oportunidad para validar sus preocupaciones y obtener el respaldo necesario.

8. El Encargo de Auditoría

El Consejo de Administración ha contratado a una firma auditora para realizar una auditoría integral del control interno y la gestión de riesgos de TI, con el objetivo de:

- Evaluar la efectividad del sistema de control interno de la cooperativa en el entorno de TI, utilizando como marco el modelo COSO.
- Identificar, analizar y evaluar los riesgos tecnológicos que enfrenta la entidad, aplicando una metodología de gestión de riesgos reconocida (COSO ERM, NIST SP 800-30 o MAGERIT).
- Determinar el grado de cumplimiento de las normas de la SIBOIF en materia de gestión de riesgos de TI y seguridad de la información.
- Emitir un informe con hallazgos, recomendaciones y un plan de acción priorizado para subsanar las deficiencias en el plazo de 90 días establecido por el regulador.

La auditoría deberá desarrollarse con un enfoque de riesgo, profundizando en aquellas áreas donde se concentran las mayores vulnerabilidades. Se espera que el equipo auditor trabaje de manera colaborativa con la Unidad de Auditoría Interna para transferir conocimientos y fortalecer sus capacidades futuras.

Documento preparado para fines académicos. Cualquier similitud con organizaciones reales es coincidencia.

Instrucciones para el Estudiante

Con base en la información proporcionada, desarrolle el proceso metodológico de auditoría de TI aplicando COSO (Control Interno) y metodologías de gestión de riesgos como COSO ERM, NIST SP 800-30 o MAGERIT como marcos de referencia principales. Para ello, deberá completar las siguientes fases:

Fase 1: Planificación

- **Enfoque de auditoría:** Justifique el tipo de enfoque que adoptará (basado en riesgos, de controles, sistémico o combinado), teniendo en cuenta la situación descrita y la urgencia regulatoria.
- **Objetivos de auditoría:** Defina al menos tres objetivos específicos y medibles (SMART) que guíen su evaluación. Deben reflejar la evaluación del control interno (componentes de COSO) y la gestión de riesgos tecnológicos.
- **Alcance de la auditoría:** Establezca los límites de su revisión: qué sistemas, procesos, ubicaciones geográficas, áreas organizativas y período de tiempo serán objeto de análisis. Considere si incluirá la revisión de los procesos de gestión de riesgos a nivel institucional.
- **Criterios de auditoría:** Identifique las normas, leyes, estándares y políticas que utilizará como referencia. Debe incluir el marco COSO (Ambiente de control, Evaluación de riesgos, Actividades de control, Información y comunicación, Supervisión), las metodologías de gestión de riesgos (COSO ERM, NIST SP 800-30, MAGERIT), las normativas de la SIBOIF sobre riesgos de TI, la Ley 1042 y las políticas internas existentes.
- **Programa de trabajo:** Elabore un listado detallado de al menos diez procedimientos de auditoría (entrevistas, revisiones documentales, pruebas de cumplimiento, pruebas sustantivas, análisis de riesgos simulados, etc.) que ejecutará en la fase de trabajo de campo. Para cada procedimiento, indique el objetivo, la técnica a utilizar y el tiempo estimado.

Fase 2: Trabajo de Campo (Simulado)

Para cada uno de los siguientes componentes de COSO o áreas de gestión de riesgos, simule la aplicación de al menos una técnica de auditoría y presente la evidencia obtenida (en forma de resumen de entrevista, tabla de datos analizados, captura de pantalla ficticia, etc.):

Componente / área	Aspecto a evaluar	Técnica sugerida
Ambiente de control	Filosofía de la dirección, estructura organizativa, asignación de autoridad, políticas de recursos humanos, integridad y valores éticos.	Entrevista con el Gerente General y con miembros del Consejo; revisión de actas de reuniones.
Evaluación de riesgos	Identificación de activos críticos, análisis de amenazas y vulnerabilidades, determinación de probabilidad e impacto, establecimiento de respuestas al riesgo.	Aplicación simulada de una metodología de análisis de riesgos (ej. NIST 800-30) para los sistemas core, banca en línea y respaldos.
Actividades de control	Controles generales de TI (seguridad lógica, gestión de cambios, continuidad, seguridad física) y controles de aplicación (validaciones, segregación de funciones, pistas de auditoría).	Prueba de cumplimiento sobre la segregación de funciones en el core bancario; revisión de usuarios activos y permisos; inspección física de la sala de servidores.
Información y comunicación	Canales de comunicación de políticas, reportes a la gerencia y al Consejo, flujo de información entre áreas.	Revisión de actas y reportes; entrevista con personal de sucursales; análisis de si existe un código de ética difundido.
Supervisión	Actividades de monitoreo continuo, auditoría interna, seguimiento de deficiencias.	Revisión del plan anual de auditoría interna; entrevista con el auditor interno; análisis del estado de recomendaciones previas.

Fase 3: Desarrollo de Hallazgos e Informe

- Identifique al menos tres hallazgos significativos relacionados con el control interno y la gestión de riesgos de TI. Para cada hallazgo, desarrolle los cinco atributos:
- Condición: ¿Qué encontró? (describa el hecho concreto basado en las evidencias simuladas)
- Criterio: ¿Qué debería ser? (indique la referencia a COSO, metodología de riesgos utilizada, normativas de la SIBOIF, Ley 1042, etc.)
- Causa: ¿Por qué ocurre? (identifique la causa raíz, no la excusa)
- Efecto: ¿Qué consecuencias tiene? (impacto en la consecución de los objetivos institucionales, en el cumplimiento regulatorio, en la confianza de los socios)
- Recomendación: ¿Qué hacer para corregirlo? (propuesta concreta y viable, incluyendo acciones a corto plazo para cumplir con el plazo de 90 días)

Redacte luego el informe de auditoría completo, con la siguiente estructura:

- Encabezado (destinatario, auditores, fecha, período auditado)
- Resumen ejecutivo (máximo una página, lenguaje no técnico, con énfasis en los riesgos regulatorios)
- Objetivos y alcance
- Limitaciones (si las hubiera)
- Detalle de hallazgos (para cada uno, presentar los cinco atributos)
- Conclusiones generales (incluyendo una valoración de la madurez del control interno y la gestión de riesgos)
- Anexos (evidencias clave, listado de entrevistados, matriz de riesgos elaborada, etc.)

Fase 4: Seguimiento

Elabore un plan de acción para implementar las recomendaciones derivadas de los hallazgos.

Debe incluir:

- Actividades correctivas específicas, diferenciando aquellas que deben ejecutarse dentro del plazo de 90 días exigido por la SIBOIF y las que forman parte de una estrategia de mediano plazo.
- Responsable(s) asignado(s) (cargos, no nombres personales)
- Plazo de implementación (fechas concretas)
- Indicador de cumplimiento (¿cómo saber que se logró?)

Además, describa la estrategia de seguimiento que realizará como auditor para verificar que las recomendaciones se implementaron de manera efectiva: plazos de revisión, evidencias a solicitar, y cómo se comunicarán los avances a la SIBOIF.